

PHISHING INCIDENT RESPONSE PLAYBOOK

Resolución del incidente

Detección • Análisis • Contención • Erradicación • Recuperación



Samuel Romero De los Reyes

Administración de Sistemas y Ciberseguridad

2026

Contenido

1. Resumen de la descripción del caso.....	2
2. ¿Qué ha pasado?.....	2
3. Contestación a las preguntas planteadas en el diagrama.....	3
3.1. ¿A quién afecta?.....	3
3.2. ¿Tiene repercusiones legales o contractuales?.....	3
3.3. ¿Es un delito que podamos denunciar?.....	3
3.4. ¿Sabemos dónde se denuncia?.....	4
3.5. ¿Tendremos que guardar evidencias para hacer la denuncia?.....	4
3.6. ¿Sabemos a quién pedir ayuda y soporte?.....	4
3.7. ¿Tenemos recursos para contener el incidente?.....	4
3.8. Los servicios y sistemas afectados, ¿están bajo nuestro control o externalizados?.....	4
3.9. ¿Qué decirles y cómo? Estrategia de comunicación.....	5
4. Solución propuesta.....	5
5. Conclusión.....	5

1. Resumen de la descripción del caso

La organización afectada es una pequeña empresa que dispone de una página web o tienda online para interactuar con sus clientes. La empresa tiene contratados servicios de conexión a Internet, alojamiento web y soporte informático, y varias personas administran y actualizan los contenidos publicados en la web. Entre ellas se encuentra una trabajadora de reciente incorporación.

El incidente se detecta cuando un cliente comunica por teléfono que, al intentar acceder a la página web de la empresa, aparece una página que suplanta a la de un banco conocido. Además, el navegador muestra un aviso indicando que la web figura en una lista negra de phishing. Tras revisar la situación, se concluye que un tercero no autorizado accedió al servidor web y sustituyó el contenido legítimo por una página fraudulenta destinada al robo de credenciales bancarias. La causa más probable del acceso fue la entrega de las credenciales de administración por parte de una empleada que recibió una llamada haciéndose pasar por el proveedor tecnológico.

Por tanto, se trata de un incidente de seguridad grave que combina ingeniería social, uso indebido de credenciales válidas y modificación maliciosa del contenido de la web corporativa para cometer phishing contra terceros. El incidente afecta tanto a la disponibilidad e integridad de la página web como a la reputación de la empresa, y puede tener implicaciones legales, contractuales y de protección de datos.

2. ¿Qué ha pasado?

Lo ocurrido puede resumirse del siguiente modo:

Un atacante contactó telefónicamente con una de las personas que administraban la web y, simulando ser el proveedor tecnológico, solicitó las credenciales con la excusa de realizar una actualización urgente. La empleada, al no conocer todavía bien los procedimientos internos ni al proveedor, facilitó los datos de acceso. Posteriormente, el atacante utilizó esas credenciales para acceder al gestor de contenidos o al panel de administración del sitio web y reemplazó la página original por una copia fraudulenta de la web de un banco. El objetivo era engañar a visitantes externos para que introdujeran sus usuarios y contraseñas.

Este incidente no solo compromete la página web de la empresa, sino que también la convierte temporalmente en infraestructura al servicio de un fraude contra terceros. Además, el hecho de que el software web pudiera estar desactualizado agrava el riesgo, ya que revela debilidades previas de seguridad que podrían haber sido aprovechadas también por otras vías.



3. Contestación a las preguntas planteadas en el diagrama

3.1. ¿A quién afecta?

Afecta a varios grupos de interés.

En primer lugar, afecta a los clientes y visitantes de la página web, ya que pueden acceder a una web fraudulenta y entregar sus credenciales bancarias creyendo que navegan por un entorno legítimo. También afecta a la propia empresa, porque su sitio web ha sido comprometido, su imagen se ve perjudicada y puede sufrir pérdida de confianza, reclamaciones o perjuicios económicos. Igualmente afecta a los empleados y administradores de la web, especialmente al personal responsable de su gestión, porque sus credenciales han quedado comprometidas y sus equipos podrían haber sido utilizados o afectados. Finalmente, también afecta al proveedor de alojamiento web y al soporte técnico, ya que deben intervenir de forma inmediata en la contención y recuperación del servicio.

3.2. ¿Tiene repercusiones legales o contractuales?

Sí, puede tenerlas.

Existen posibles repercusiones legales porque la página comprometida ha sido utilizada para una actividad ilícita de phishing. Aunque la empresa sea víctima, debe preservar evidencias, colaborar con las autoridades y demostrar diligencia en la gestión del incidente. Además, si se hubieran tratado o expuesto datos personales, habría que analizar la posible obligación de notificación a la autoridad competente y, en su caso, a los afectados, conforme a la normativa de protección de datos aplicable.

También pueden existir repercusiones contractuales, por ejemplo con clientes, con el proveedor de alojamiento o con terceros que esperaban un servicio seguro y disponible. Será necesario revisar contratos, acuerdos de nivel de servicio, cláusulas de seguridad y obligaciones de notificación.

3.3. ¿Es un delito que podamos denunciar?

Sí. Se trata de un incidente claramente denunciable, ya que implica acceso no autorizado, suplantación, uso fraudulento de la infraestructura corporativa y captación ilícita de credenciales. La solución orientativa del reto indica expresamente que debe contactarse con la policía y con INCIBE, así como conservar pruebas para adjuntarlas a la denuncia.

3.4. ¿Sabemos dónde se denuncia?

La denuncia debe presentarse ante las Fuerzas y Cuerpos de Seguridad del Estado. Adicionalmente, puede solicitarse apoyo y orientación a INCIBE, tal y como recoge la solución del reto.

3.5. ¿Tendremos que guardar evidencias para hacer la denuncia?

Sí, de forma obligatoria desde el punto de vista técnico y muy recomendable desde el punto de vista legal.

Deben preservarse, al menos, una copia cifrada de la web comprometida, los registros del servidor, los logs de acceso, capturas de pantalla, fechas y horas de los eventos, credenciales afectadas, comunicaciones relacionadas con el incidente y cualquier otro artefacto útil para análisis forense. La solución del reto señala expresamente la necesidad de conservar la copia de la web y de los registros del servidor para entregarlos junto con la denuncia.

3.6. ¿Sabemos a quién pedir ayuda y soporte?

Sí. Debe activarse al menos este circuito de apoyo:

- Responsable interno de TI o seguridad.
- Proveedor de alojamiento web.
- Soporte informático.
- INCIBE para orientación especializada.
- Fuerzas y Cuerpos de Seguridad para la denuncia.
- Asesoría legal o delegado de protección de datos, si procede.

3.7. ¿Tenemos recursos para contener el incidente?

Si la empresa no dispone de capacidad técnica suficiente, deberá apoyarse en el proveedor y en el soporte externo. El reto deja claro que parte de los servicios están externalizados, por lo que la contención debe coordinarse con el proveedor de alojamiento y soporte técnico.

3.8. Los servicios y sistemas afectados, ¿están bajo nuestro control o externalizados?

En este caso, los servicios están parcialmente externalizados, porque la empresa utiliza proveedor de alojamiento web y soporte informático. Por ello, aunque la responsabilidad de gestión del incidente sigue siendo de la empresa, muchas acciones técnicas deberán ejecutarse con el proveedor.

3.9. ¿Qué decirles y cómo? Estrategia de comunicación

La comunicación debe ser clara, breve, veraz y coordinada.

Internamente, debe informarse a dirección, al equipo de TI, al área legal y al personal que gestiona la web. Externamente, si se confirma el riesgo para clientes o usuarios, debe comunicarse que la web ha sufrido un incidente de seguridad, que el sitio ha sido retirado temporalmente o aislado por precaución, que no deben introducir credenciales, y que la empresa está trabajando con proveedores y autoridades para resolver el incidente. Si hubiera indicios de tratamiento o exposición de datos personales, la notificación deberá ajustarse también a las exigencias legales aplicables.

4. Solución propuesta

La respuesta adecuada se basa en cuatro líneas: contención, mitigación, recuperación y notificación.

La primera medida debe ser poner la web fuera de servicio o aislarla para detener de inmediato el fraude. Después, deben cambiarse todas las credenciales comprometidas, especialmente las cuentas de administración, y revisar si existen usuarios, tareas, archivos o accesos sospechosos. La empresa debe preservar evidencias, contactar con el proveedor de alojamiento, con el soporte técnico, con INCIBE y con las autoridades, y analizar el alcance real del incidente. Estas acciones están alineadas con la solución oficial del reto.

A continuación, se debe realizar una revisión completa del entorno: análisis de malware, comprobación de integridad de la web, revisión de logs, actualización del gestor de contenidos, plugins, temas y componentes, así como endurecimiento de accesos y permisos. Una vez controlado el incidente, la web debe restaurarse desde una copia de seguridad fiable y verificarse antes de volver a publicarse. Finalmente, habrá que solicitar la retirada de la web de listas negras y establecer medidas preventivas para evitar recurrencias, como formación frente a ingeniería social, revisión de permisos, política robusta de contraseñas y auditorías periódicas.

5. Conclusión

El incidente analizado demuestra cómo una acción de ingeniería social aparentemente sencilla puede comprometer la web corporativa y convertirla en una plataforma de phishing contra terceros. La prioridad debe centrarse en detener el fraude, conservar evidencias, coordinar la respuesta con proveedor, soporte y autoridades, restaurar el servicio de forma segura y adoptar medidas correctivas y preventivas. La empresa no solo debe recuperar la web, sino también reforzar sus procedimientos internos, su política de accesos y la formación del personal para reducir el riesgo de repetición.